توثيق الوحدة A2 — المستخدمون والأدوار والصلاحيات

بند	البيان
بند	البيان
اسم الوثيقة	A2_Users_Roles_Unit_Documentation
الإصدار	v1.0
التاريخ	2026-09-21
مُعدّ الوثيقة	كبير المطورين
مرجع الإعداد	التوجيه الاستشاري CD-005
الوحدة	A2 — المستخدمون والأدوار والصلاحيات (Users, Roles & Permissions)
النطاق	دراسة/توثيق قراءة فقط — لا تغييرات في الشيفرة ولا في قاعدة البيانات
التسليم	إدارة المشروع فقط
الحالة	مكتملة — بانتظار اعتماد كبير المستشارين + إدارة المشروع

ملاحظات منهجية (مُعلنة صراحة): ـ الدراسة قائمة على **القراءة فقط** للشيفرة المصدرية وللمخطط/البيانات الحية؛ لم تُجرَ اختبارات تشغيلية ولا أي كتابة في قاعدة البيانات (كل استعلامات الفحص SELECT/SHOW فقط). ـ **لقطات الشاشات غير متوفرة:** تُوثَّق الشاشات من **مصدر HTML/العرض المباشر** مع مراجع الأسطر، على نفس منهج وثيقة A1. - جميع المراجع بصيغة ملف:سطر لأغراض التحقق. ـ **اكتشاف جوهري أثناء الدراسة:** ملف عرض إنشاء المستخدم app/Views/admin/users/create.php **تالف/مُستبدَل** بمحتوى باني القوالب (ترميز مشوّه)، فتكون شاشة «إضافة مستخدم جديد» **معطوبة كليًا**. يُدرَج التفصيل في §8–1 و§9 (G1) و§11 (P1). - **البيانات الحية ملوّثة ببقايا اختبارات CD-004:** جدول users يحوي **58 حسابًا اختباريًا** (*_cd004.*@test.local / test) لم تُنظَّف، مقابل **4 حسابات حقيقية** فقط. لذلك تُفصَّل الأرقام في §1 (حقيقي مقابل إجمالي) — ولا تُقرأ الأرقام الإجمالية كنمو فعلي. ـ **لا يوجد اختبار مخصّص للوحدة A2** (المجموعة الحالية: Core فقط — Auth/Notification/Helpers/Database). يُدرَج في §8/§9.

---

1. نظرة عامة على الوحدة

وحدة A2 هي المسؤولة عن **إدارة الهويات والوصول** في النظام: إنشاء حسابات الوصول وربطها بالموظفين، وتعريف الأدوار، وضبط الصلاحيات الممنوحة لكل دور، وتدقيق كل تغيير يمسّ المستخدمين أو الأدوار أو الصلاحيات. تعتمد الوحدة على أساس المصادقة المنجز في **A1** (الجلسة + RBAC + حماية CSRF + انعاش الصلاحيات).

الجانب	الوصف	المرجع
الجانب	الوصف	المرجع
إدارة المستخدمين	إنشاء/تعديل/حذف/تفعيل ـ تعليق/إعادة تعيين/تغيير الدور	Admin\UserController.php
إدارة الأدوار	إنشاء/تعديل وصف/حذف الأدوار غير النظامية	Admin\RoleController.php
إدارة الصلاحيات	منح/سحب صلاحية لكل دور (AJAX) — **صفحة واحدة مدمجة داخل admin/roles**	admin/roles/index.php, main.js:527–584
نموذج البيانات	role_permissions (many-to-many مزدوج) + user_roles + permissions + roles	db_live_schema.sql
الحارس	'Auth::is('Admin للمستخدمين، و'Auth::can('roles.manage للأدوار	UserController.php:21–30 RoleController.php:10–13
التدقيق	تسجيل كل إجراءات A2 في audit_logs	Audit.php:18–44

الأرقام الحية (فحص قراءة فقط على employee_evaluation_mvc في 2026-09-21):

العنصر	حقيقي (مُنقّى من بقايا الاختبار)	إجمالي حي	المصدر
العنصر	حقيقي (مُنقّى من بقايا الاختبار)	إجمالي حي	المصدر
حسابات المستخدمين	**4**	62 (AUTO_INCREMENT=549)	SELECT users + فلترة %_cd004.%/test
الأدوار	**4** (كلها is_system_role=1)	4 (AUTO_INCREMENT=39)	SELECT roles
الصلاحيات	**36**	36 (AUTO_INCREMENT=37)	SELECT permissions
ربط مستخدم↔دور	**4**	37	SELECT user_roles
ربط دور↔صلاحية	**39**	39	SELECT role_permissions
سجلات التدقيق	—	682 (AUTO_INCREMENT=682)؛ إجراءات A2 فعلية = 40 فقط	SELECT audit_logs

توزيع الصلاحيات الفعلي على الأدوار (حي):

الدور	عدد الصلاحيات	الصلاحيات
الدور	عدد الصلاحيات	الصلاحيات
Admin	**35 من 36**	كل الصلاحيات **عدا** 23 id) **positions.manage**)
HR	2	templates.manage, training.manage
Manager	**0**	لا شيء
Staff	2	branches.manage, departments.view

> **تعارض موثَّق:** Org_Structure.md:132_02 يذكر «Admin = كل شيء (36 صلاحية)»، لكن البيانات الحية تُثبت أن دور Admin يملك **35** فقط ويفتقده positions.manage. يُدرَج في §8-7.

توزيع الحسابات الحقيقية (4): fzahrani↔HR، smutairi↔Staff، kghamdi↔Manager، sysadmin↔Admin. الحالات: الكل active (الإجمالي الحي: 54 invited, 4 suspended, 4 active — وأغلبها بقايا اختبار).

---

2. الملفات والمكونات

2.1 المتحكمات

الملف	الدور	ملاحظات
الملف	الدور	ملاحظات
app/Controllers/Admin/UserController.php (352 سطرًا)	index / create / store / edit / update / destroy / updateRole / toggleStatus / resetPassword (9 دوال)	الحارس: Auth::is('Admin') **باسم الدور لا بصلاحية** + exit + **users.view** (بند A1 7)
app/Controllers/Admin/RoleController.php (217 سطرًا)	index / create / store / update / destroy / updatePermission (6 دوال)	الحارس: Auth::can('roles.manage')

2.2 النماذج (Models)

الملف	الدوال	ملاحظات

الملف	الدوال	ملاحظات
الملف	الدوال	ملاحظات
app/Models/User.php (435 سطرًا)	findByUsernameOrEmail, findById, getPermissions, getAll, updateRole, delete, hasRole, getUserRoles, getUserPermissions, getAllWithDetails, updateLastLogin, createUser, toggleStatus, updateUser, deleteUser, guardPasswordChange, updatePassword	createUser داخل Transaction؛ updateRole **بلا Transaction** (حذف ثم إدراج)
app/Models/Role.php (182 سطرًا)	getAll, getAllPermissions, getRolePermissions, addPermissionToRole, removePermissionFromRole, createRole, updateRole, deleteRole, findById	**يحتضن منطق الصلاحيات بالكامل — لا يوجد Permission model**

2.3 العروض (Views)

الملف	الأسطر	الحالة
الملف	الأسطر	الحالة
app/Views/admin/users/index.php	149	سليمة — جدول المستخدمين + نافذة تغيير الدور
app/Views/admin/users/create.php	372	**تالف/مُستبدَل** — بحته، markup باني القوالب (form-builder-container, "action="/templates/save") بترميز مشوّه، **لا نموذج مستخدم**
app/Views/admin/users/edit.php	69	سليمة — الحساب + كلمة المرور الاختيارية + الربط الوظيفي
app/Views/admin/roles/index.php	176	سليمة — بطاقات الأدوار + مفاتيح الصلاحيات + نافذة تعديل الدور
app/Views/admin/roles/create.php	44	سليمة — نموذج إنشاء دور

2.4 المسارات (15 — routes/web.php:78–95) مسارًا

#	المسار	الدالة	الحماية
#	المسار	الدالة	الحماية
1	GET /admin/users	UserController@index	Auth::is('Admin')
2	GET /admin/users/create	UserController@create	Auth::is('Admin')
3	POST /admin/users	UserController@store	Auth::is('Admin')
4	GET /admin/users/edit/:id	UserController@edit	Auth::is('Admin')
5	POST /admin/users/update	UserController@update	Auth::is('Admin')
6	POST /admin/users/delete	UserController@destroy	Auth::is('Admin')
7	POST /admin/users/update-role	UserController@updateRole	Auth::is('Admin')
8	POST /admin/users/toggle-status	UserController@toggleStatus	Auth::is('Admin')
9	POST /admin/users/reset-password	UserController@resetPassword	Auth::is('Admin')
10	GET /admin/roles	RoleController@index	Auth::can('roles.manage
11	GET /admin/roles/create	RoleController@create	Auth::can('roles.manage
12	POST /admin/roles	RoleController@store	Auth::can('roles.manage
13	POST /admin/roles/update	RoleController@update	Auth::can('roles.manage
14	POST /admin/roles/delete	RoleController@destroy	Auth::can('roles.manage
15	POST /admin/roles/update-permission	RoleController@updatePermission	Auth::can('roles.manage

> **لا يوجد أي مسار admin/permissions/** ولا متحكم/شاشة مستقلة للصلاحيات (المذكور في التوجيه). إدارة الصلاحيات مدمجة داخل admin/roles. يُدرَج في §9 (G2).

2.5 جافاسكربت (public/js/main.js)

المقطع	الأسطر	الوظيفة
المقطع	الأسطر	الوظيفة
تغيير دور المستخدم	493–520	يملأ نافذة editUserRoleModal ويفتحها
مفاتيح الصلاحيات	527–584	fetch POST /admin/roles/update-permission مع هيدر X-CSRF-Token
تعديل الدور	593–612	يملأ نافذة editRoleModal (الاسم للقراءة فقط)
حذف الدور	615–647	تأكيد Swal ثم إرسال نموذج POST admin/roles/delete
تفعيل/تعليق المستخدم	651–697	fetch POST /admin/users/toggle-status + إعادة تحميل
حذف المستخدم	703–732	تأكيد Swal ثم نموذج POST admin/users/delete
إعادة تعيين كلمة المرور	736–790	fetch POST /admin/users/reset-password + عرض الكلمة الجديدة

ملاحظة: مسارات العنونة الثابتة /employee-evaluation/... مضمّنة نصيًا في JS (لا تُستخدم APP_URL)، وهو قيد قابلية نقل.

2.6 الجداول المرتبطة (db_live_schema.sql)

الجدول	السطر	أبرز الأعمدة/القيود
الجدول	السطر	أبرز الأعمدة/القيود
permissions	489	name فريد، description, category
role_permissions	550	PK مركّب (role_id, permission_id)، FK CASCADE
roles	561	name فريد، is_system_role
user_roles	641	PK مركّب (user_id, role_id)، FK CASCADE
users	652	username/email فريدان، employee_id، password_hash، status (افتراضي enum(active,suspended,invited)، last_login_at، must_change_password، permissions_version، FK CASCADE)
audit_logs	54	user_id (FK SET NULL)، action، entity_type، entity_id، details (JSON نصي)، ip_address

2.7 المكوّنات المساندة

الملف	الدور
الملف	الدور
app/Core/Auth.php	is/hasRole/isAdmin/userHasPermission/can، انعاش الصلاحيات، سياسة كلمة المرور، CSRF
app/Core/Controller.php	view/redirect/json
app/Core/Audit.php	الكتابة في audit_logs (يبتلع الأخطاء)
app/Controllers/ErrorController.php	forbidden(403) / notFound(404)
app/Views/layouts/header.php:401–414	قائمة لوحة المدير (المستخدمون/الأدوار) — **مقيّدة بـ Auth::isAdmin() فقط**

---

3. دورة العمل الفعلية (Workflow)

3.1 حارس الوحدة (كلا المتحكمين)

1. (UserController::__construct 21–30): إن لم يكن Auth::is('Admin') ⟵ ErrorController->forbidden ثم exit (الإصلاحُ بند 7 من A1).

2. Auth::can('roles.manage') (10–13): ('RoleController::__construct') (تُظهر 403 وتُنهي عند الفشل).
3. قائمة لوحة المدير في الهيدر لا تظهر إلا لـ Admin (header.php:401)، مع أن متحكم الأدوار يقبل أي مالكٍ للصلاحية roles.manage.

3.2 إنشاء مستخدم — معطّل عمليًا

1. create() (99–113) GET /admin/users/create يجلب الأدوار + الموظفين غير المرتبطين ثم يعرض admin/users/create.
2. **العطل:** العرض create.php لا يحوي حقول المستخدم (username/email/password/password_confirm/role_id/employee_id) بل واجهة باني القوالب؛ فلا نموذج يُرسَل أصلًا.
3. store() (122–179) يتحقق من الطلب والحقول ويطابق كلمتي المرور ويفرض سياسة validatePasswordPolicy (A1) ثم User::createUser() داخل Transaction) users + user_roles) ويسجّل USER_CREATE.
4. عند التكرار (اسم/بريد/موظف) يعيد createUser القيمة false (خطأ 23000) مع Flash «فشل إنشاء المستخدم...».
5. **نقص:** لا تحقق من إلزامية role_id، ولا من وجود الموظف، ولا من تعارض ربط الموظف.

3.3 تعديل مستخدم

findById :(223–240) edit($id) (مع role_name وfull_name) أو 404. 280–242) update()): يفرض سياسة كلمة المرور عند إدخال كلمة جديدة، ثم User::updateUser() ويسجّل USER_UPDATE.

3.4 تغيير دور المستخدم

POST :(59–91) updateRole()، **يمنع تغيير دور الذات** (71–75)، ثم User::updateRole (حذف كل أدوار المستخدم ثم إدراج الدور الجديد — بلا Transaction)، ويُسجّل USER_ROLE_UPDATE.

3.5 تفعيل/تعليق المستخدم

JSON :(187–220) toggleStatus()، **يمنع تعليق الذات** (202–206)، ثم User::toggleStatus (تبديل active suspended، ولا يعالج invited)، ويسجّل USER_ACTIVATED أو USER_SUSPENDED.

3.6 إعادة تعيين كلمة المرور

JSON :(311–351) resetPassword()، **يمنع استخدامها على الذات**، يولّد كلمة قوية (generateStrongPassword(12)) ويعيدها في الاستجابة مرة واحدة، ويضبط updatePassword(..., true) must_change_password=1 (بند A1 9)، ويسجّل USER_PASSWORD_RESET.

3.7 حذف مستخدم

POST :(282–303) destroy()، **يمنع حذف الذات**، ثم User::deleteUser (FK CASCADE يحذف user_roles) ويسجّل USER_DELETE. لا منع لحذف آخر Admin.

3.8 إنشاء/تعديل/حذف دور

- store() (143–174): يتحقق من الاسم والوصف، Role::createRole (تُجبر is_system_role=0)، ويسجّل ROLE_CREATE.
- update() (179–196): يحدّث **الوصف فقط**، وRole::updateRole تضيف is_system_role=0 فلا تُعدَّل أدوار النظام، ويسجّل ROLE_UPDATE.
- Role::deleteRole :(198–213) destroy() تضيف is_system_role=0، وتمنع 23000 (FK) حذف دور مُسنَد، ويسجّل ROLE_DELETE.

3.9 تعديل صلاحيات دور (AJAX)

updatePermission() (57–117): POST JSON، **يرفض دور «Admin» بالاسم** (87–92)، ثم addPermissionToRole/removePermissionFromRole ويسجّل PERMISSION_ADDED/PERMISSION_REMOVED. تغيير الدور يرفع permissions_version عبر مشغّلات بند 8 (A1) فيُعاد بناء جلسات المتأثرين.

---

4. الشاشات

> لقطات الشاشات غير متوفرة؛ تُوثَّق من مصدر العرض. مدخل الشاشتين من قائمة لوحة المدير (header.php:401–414).

4.1 قائمة المستخدمين — admin/users/index.php

العنصر	التفاصيل	السطر
العنصر	التفاصيل	السطر
عنوان + زر الإضافة	«إدارة المستخدمين» + «إضافة مستخدم جديد» ⚿ admin/users/create/	6–12
الأعمدة	اسم المستخدم، البريد، الموظف المرتبط (employee_name ?? N/A)، الدور الحالي (role_name ?? بدون دور)، الحالة، آخر دخول، الإجراءات	17–25
أزرار الإجراءات	تعديل، تغيير الدور (modal)، تفعيل/تعليق (حسب الحالة)، إعادة تعيين، حذف	50–101
الحالة الفارغة	«لا يوجد مستخدمين لعرضهم.»	107–109
نافذة تغيير الدور	csrf_field + POST /admin/users/update-role() + حقل user_id مخفي + قائمة role_id	116–144

4.2 إنشاء مستخدم — admin/users/create.php تالف

- المحتوى الفعلي: form-builder-container + مكتبة عناصر + "form id="templateForm" ... action="/templates/save + معاينة قوالب (الأسطر 13–160)، **والترميز مشوّه** (نصوص عربية غير قابلة للقراءة، أسطر 2–7).
- لا يحتوي الحقول التي يتوقعها (username,email,password,password_confirm,role_id,employee_id store()). النتيجة: **شاشة الإضافة غير قابلة للاستخدام**.
- الأثر: مسار POST /admin/users غير قابل للوصول من الواجهة عمليًا.

4.3 تعديل مستخدم — admin/users/edit.php

العنصر	السطر
العنصر	السطر
معلومات الحساب: email + username (إلزاميان)	19–28
تغيير كلمة المرور (اختياري): password + password_confirm	33–45
الربط الوظيفي: employee_id (خيار «لا يوجد ربط»)	46–57
النموذج	csrf_field + POST /admin/users/update() + حقل id مخفي

4.4 إدارة الأدوار — admin/roles/index.php

العنصر	السطر
العنصر	السطر
شبكة البطاقات + زر «إضافة دور جديد»	19–36

العنصر	السطر
شارة «دور نظام» (للأدوار النظامية) أو أزرار تعديل/حذف (لغير النظامية)	76–41
وصف الدور + مفاتيح الصلاحيات مصنّفة بالفئة	117–79
مفتاح Admin معطّل (disabled)	105–103
نافذة تعديل الدور: POST /admin/roles/update — الاسم للقراءة فقط، الوصف قابل للتعديل	170–136

4.5 إنشاء دور — admin/roles/create.php

- الاسم: pattern="[A-Za-z]+" إلزامي (أحرف إنجليزية)، والوصف إلزامي بالعربية؛ النموذج csrf_field() + POST /admin/roles (15–39).

4.6 نافذة تغيير دور المستخدم

- قائمة الأدوار تُبنى من $roles؛ الحقل role_id إلزامي؛ بعد الحفظ إعادة توجيه لـ admin/users/ (عبر المتحكم).

---

5. قواعد العمل

#	القاعدة	الموضع
#	القاعدة	الموضع
1	الوصول لإدارة المستخدمين مقيّد بالدور Admin **بالاسم** (لا بصلاحية users.view)	UserController.php:24
2	الوصول لإدارة الأدوار مقيّد بالصلاحية roles.manage	RoleController.php:12
3	username وemail فريدان على مستوى الجدول	users schema
4	employee_id فريد وربط اختياري؛ FK CASCADE	users schema
5	كلمة المرور تُخزَّن password_hash(PASSWORD_DEFAULT) وتخضع لسياسة A1 (طول ≥8، تنوع 3/4، قائمة شائعة، نبذ آخر 3)	User.php:234,325,418, Auth.php:614
6	إعادة التعيين الإدارية تُلزم التغيير عند الدخول التالي (must_change_password=1)	UserController.php:336
7	لا يمكن للمدير تغيير دوره / تعليق حسابه / حذفه / إعادة تعيين كلمة مروره	UserController.php:71,202,287,326
8	لا تُعدَّل/تُحذف أدوار النظام (is_system_role=1)	Role.php:143,153
9	لا تُعدَّل صلاحيات دور Admin	RoleController.php:88
10	حذف دور مُسنَد لمستخدمين يمنعه المفتاح الخارجي	Role.php:150–165
11	تغيير دور المستخدم يستبدل كل أدواره (حذف الكل ثم إدراج الجديد)	User.php:99–111
12	كل تغيير يُرفع permissions_version فيُبطل جلسات المتأثرين	مشغّلات بند 8 (A1)
13	كل إجراء إداري يُسجَّل في audit_logs مع IP	Audit.php:18
14	status ثلاث حالات، والتبديل يمسّ active⇄suspended فقط (invited لا يُبثّ)	User.php:285–308
15	الحارس يعتمد **اسم الدور** لا الصلاحية، وقيود «الذات» مواضع فقط بلا قفل مركزي	UserController

---

6. الأمان والصلاحيات الحالي

المحور	الآلية	المرجع
المحور	الآلية	المرجع

المحور	الآلية	المرجع
حارس المستخدمين	Auth::is('Admin') (فحص $_SESSION['user_roles'] + exit بعد 403)	Auth.php:35, UserController.php:21–30
حارس الأدوار	Auth::can('roles.manage') عند الفشل 403	Auth.php:100, RoleController.php:12
تجاوز Admin	userHasPermission يعيد true دائمًا لـ Admin	Auth.php:84–92
نموذج الصلاحيات	RBAC مزدوج (many-to-many) user_roles + role_permissions، **بلا Permission model**	Role.php, schema 550/641
CSRF	كل POST محمي عبر enforceCsrfToken؛ AJAX يرسل X-CSRF-Token	Auth.php:201, main.js:546,676,758
التدقيق	13 ثابت PERMISSION_*، ROLE_*، USER_* نمطًا) مع IP وentity_type/entity_id	Audit.php, UserController, RoleController
انعاش الصلاحيات	تعديل الأدوار/الصلاحيات يرفع النسخة فيُبطل الجلسة (إعادة دخول)	Auth.php:427–503
سياسة كلمة المرور	مفروضة عند الإنشاء/التعديل/إعادة التعيين	Auth.php:614, User.php
آخر Admin	**لا يوجد حارس** يمنع خفض/حذف آخر حساب Admin، ولا منع تصعيد الصلاحيات	UserController (غياب)
شاشات الإدارة	قائمة الهيدر لـ Admin فقط، لكن متحكم الأدوار يقبل roles.manage (تعارض عرض/تحقق)	header.php:401 vs RoleController

---

7. نقاط القوة

#	نقطة القوة	الدليل
#	نقطة القوة	الدليل
1	**حارس مُصلَح ومُنهٍ للتنفيذ** في كلا المتحكمين (exit بعد 403)	UserController.php:24–28
2	**تفويض دقيق للأدوار** بصلاحية roles.manage بدل اسم الدور	RoleController.php:12
3	**فصل المستخدم عن الموظف** (حساب وصول مستقل عن هوية الموظف)	schema 657
4	**RBAC مزدوج نظيف** عبر جدولَي ربط بـ PK مركّب وFK CASCADE	schema 550/641
5	**استعلامات مُعدّة بالكامل** (لا إدراج مباشر للمدخلات)	User.php, Role.php
6	**حماية أدوار النظام**: لا تعديل/حذف (is_system_role=0) في كل جملة	Role.php:143,153
7	**منع تعديل صلاحيات Admin** في طبقة المتحكم وفي الواجهة (disabled)	RoleController.php:88, roles/index.php:103
8	**حمايات «الذات»** الأربع (الدور/الحالة/الحذف/كلمة المرور)	UserController.php:71,202,287,326
9	**تدقيق شامل** لكل إجراءات A2 مع IP وJSON تفاصيل	Audit.php, UserController, RoleController
10	**تكامل مع انعاش الصلاحيات (A1 بند 8)** — تغيير الدور يبطل الجلسة تلقائيًا	Auth.php:494, مشغّلات بند 8
11	**سياسة كلمة مرور موحّدة** مفروضة على كل مسارات A2	Auth.php:614, User.php:325,418
12	**توليد كلمة مرور قوية CSPRNG** مطابقة للسياسة لإعادة التعيين	Auth.php:648

---

8. نقاط الضعف

#	الضعف	الموضع	الأثر
#	الضعف	الموضع	الأثر
1	**شاشة إنشاء المستخدم تالفة** — عرض create.php يحوي باني القوالب بدل نموذج المستخدم، بترميز مشوّه؛ المتحكم يتوقع حقولًا غير موجودة	Views/admin/users/create.php vs UserController.php:99–137	**تعذّر إنشاء أي مستخدم من الواجهة**

#	الضعف	الموضع	الأثر
2	**صلاحيات users.* الأربع غير مستخدمة إطلاقًا** — الحارس اسم الدور لا الصلاحية	permissions مقابل 1–4 UserController.php:24	فجوة معمارية RBAC؛ لا تفويض جزئي لإدارة المستخدمين
3	**لا يوجد Permission model ولا مسار/شاشة admin/permissions/** — الصلاحيات مدمجة داخل Role/admin/roles	Role.php, routes/web.php:89–95	فجوة معمارية مقابل التوجيه؛ صعوبة التوسّع
4	**لا حارس لآخر Admin** — لا منع حذف/تعليق/خفض آخر Admin (يُمنع فقط إجراء الذات)	UserController.php (غياب)	**قفل كامل للنظام** محتمل
5	**لا منع تصعيد الصلاحيات (Privilege Escalation)** — أي Admin (أو مالك roles.manage) يمنح أي صلاحية لأي دور	RoleController.php:57–117	تضخّم امتيازات
6	**roles.update لا يعدّل الاسم** (الوصف فقط)؛ والاسم غير قابل للتغيير بعد الإنشاء	RoleController.php:179–196	قصور وظيفي
7	**Admin يفتقد positions.manage** في البيانات الحية، خلافًا لوثيقة 02 («كل شيء 36»)	role_permissions مقابل Org_Structure.md:132_02	تعارض وثيقة/بيانات + وظيفة مفقودة
8	**Manager بلا صلاحيات Staff بصلاحيات إدارية موروثة** (branches.manage)	role_permissions, 02 §4	**خطر أمني** (Staff يملك صلاحية هيكلية واسعة)
9	**User::updateRole بلا Transaction** (حذف ثم إدراج)	User.php:99–111	مستخدم بلا دور عند فشل الإدراج
10	**لا تحقق من role_id/employee_id في store()**	UserController.php:122–160	بيانات ناقصة/معطوبة
11	**deleteUser مسار مكرر** (delete وdeleteUser) وحذف فعلي بلا تعطيل	User.php:118,382	غموض صيانة + فقدان تاريخ
12	**لا اختبارات للوحدة A2**	*/tests/cases/Core	تراجع غير محمي
13	**مسار تحقق/واجهة غير متسقة**: قائمة الهيدر Admin فقط، لكن متحكم الأدوار يقبل roles.manage	header.php:401 vs RoleController.php:12	صلاحية «غير قابلة للوصول» من الواجهة
14	**بقايا اختبار غير منزّعة** (58 حسابًا) في جدول users الحي	users	تلوّث بيانات/إحصاءات مضللة
15	**تعليقات/ترميز مشوّه** في main.js وcreate.php (أثر مراجعة)	main.js:621,657, create.php	سوء قراءة/صيانة
16	**URLs ثابتة /employee-evaluation/...** في JS بلا APP_URL	main.js:541,634,671,719,753	قيد نقل البيئة

---

9. الفجوات (جدول)

المعرّف	الفجوة (حسب قائمة CD-005)	المرجع	الأثر المحتمل	الأولوية
المعرّف	الفجوة (حسب قائمة CD-005)	المرجع	الأثر المحتمل	الأولوية
G1	**شاشة إنشاء المستخدم معطوبة** (ملف عرض مستبدل/تالف)	§1-8	تعذّر إضافة مستخدمين	**حرجة**
G2	**لا نموذج صلاحيات مستقل ولا Permission Groups/admin/permissions/**	§3-8	فجوة معمارية/توسّع	عالية
G3	**Role Hierarchy غائب** — لا تسلسل أدوار ولا وراثة	§3-8, §4-8	لا ضبط للامتيازات	عالية
G4	**لا منع حذف الذات/آخر Admin** (الأخير غير محمي)	§4-8	قفل النظام	**حرجة**
G5	**لا منع تصعيد الصلاحيات**	§5-8	تضخّم امتيازات	عالية
G6	**لا Audit شامل للتغييرات** — الفعلي يسجّل الإجراءات لكن بلا old/new values منسّقة	§6, §8	تحقيق محدود	متوسطة
G7	**لا Bulk Operations** (تفعيل/تعطيل/حذف جماعي)	UserController	بطء إداري	متوسطة

المعرّف	الفجوة (حسب قائمة CD-005)	المرجع	الأثر المحتمل	الأولوية
G8	**لا استيراد/تصدير** للمستخدمين/الأدوار	routes/web.php	عمل يدوي	متوسطة
G9	**لا قوالب أدوار (Role Templates)**	Role.php	تكرار إعداد	منخفضة
G10	**إعادة تعيين جماعي لكلمات المرور غائبة**	UserController.php:311	عمل يدوي	منخفضة
G11	**لا تقارير للوحدة** (نشاط المستخدمين/الأدوار/الصلاحيات)	routes/web.php	غياب رقابة	منخفضة
G12	**صلاحيات users.* معطّلة**	§2-8	RBAC ناقص	عالية
G13	**RBAC Manager/Staff خاطئ (إرث)**	§8-8	**خطر أمني**	**عالية**
G14	**تعارض Admin/positions.manage**	§7-8	وظيفة مفقودة	متوسطة
G15	**لا اختبارات للوحدة**	§12-8	تراجع	متوسطة
G16	**تلوّث بيانات الاختبار**	§14-8	إحصاءات مضللة	منخفضة

---

10. الأسئلة المفتوحة

1. **Manager بلا صلاحيات:** هل يُقصد أن تُدار صلاحياته برمجيًا عبر النطاق (فريقه)، أم يجب تعيين صلاحيات صريحة (evaluations, reports.view.team.*)؟
2. **Staff branches.manage:** هل هذا تعيين مقصود أم إرث خاطئ يجب تصحيحه؟ (وثيقة 12 تصنّفه خطرًا مرتفعًا R2).
3. **الأدوار الجديدة:** هل المطلوب أدوار «Deputy/مدير فرع/مشرف»؟ ومن يملك إنشاءها؟ وهل تبقى كل الأدوار الحالية نظامية؟
4. **Role Hierarchy:** هل نحتاج تسلسلًا (Admin > HR > Manager > Staff) ووراثة صلاحيات؟ أم مصفوفة مسطّحة كافية؟
5. **Permission Groups:** هل تُعاد هندسة الصلاحيات في مجموعات/وحدات قابلة للتفعيل الجماعي؟
6. **قوالب الأدوار:** هل نحتاج قوالب جاهزة (مثل «مشرف تقييم») لتسريع الإنشاء؟
7. **آخر Admin:** ما سياسة منع قفل النظام — منع حذف/خفض آخر Admin، أم إلزام وجود ≥2؟
8. **سنابشوت التدقيق:** هل تُخزَّن القيم القديمة/الجديدة (old/new) في details لكل تغيير؟
9. **الآلية الحرجة:** كيف نُصلح شاشة create.php — إعادة كتابة العرض، أم استعادة النسخة الصحيحة من نسخة احتياطية؟
10. **تنظيف البيانات:** هل نُزيل بقايا الاختبار (58 حسابًا) ضمن CD-006؟
11. **الحارس:** هل يتحوّل 'Auth::is('Admin إلى 'Auth::can('users.*' لتفعيل صلاحيات users.*؟

---

11. التوصيات

الأولوية	التوصية	التفصيل	الجهد التقديري	المخاطر إن أُجِّلت
الأولوية	التوصية	التفصيل	الجهد التقديري	المخاطر إن أُجِّلت
P1	**إصلاح شاشة انشاء المستخدم** (create.php)	إعادة كتابة العرض بالحقول التي يتوقعها store()، أو استعادة النسخة السليمة	0.5–1 يوم	استمرار العطل الوظيفي الحرج
P1	**حارس آخر Admin**	منع حذف/تعطيل/خفض آخر حساب Admin في updateRole/toggleStatus/destroy	0.5 يوم	**قفل النظام بالكامل**
P1	**تصحيح RBAC Manager/Staff**	إعادة هندسة role_permissions وفق مصفوفة معتمدة	1–2 يوم	خطر أمني

الأولوية	التوصية	التفصيل	الجهد التقديري	المخاطر إن أُجِّلت
P1	**منع تصعيد الصلاحيات**	ضبط من يملك roles.manage + تدقيق old/new على role_permissions	1 يوم	تضخّم امتيازات
P2	**تفعيل صلاحيات users.***	تحويل حارس UserController الـ ('.../Auth::can('users.view/create	1 يوم	RBAC ناقص
P2	**تنظيف بيانات الاختبار**	حذف cd004.*@test.local و*_test	0.5 يوم	إحصاءات مضللة
P2	**صرامة البيانات في store()**	التحقق من role_id/employee_id + Transaction لـupdateRole	0.5 يوم	بيانات ناقصة
P2	**توحيد التحقق/العرض**	حسم صلاحية إدارة الأدوار (اسم الدور أم roles.manage) في الهيدر والمتحكم	0.5 يوم	صلاحية غير قابلة للوصول
P3	**تغطية اختبار A2**	اختبارات إنشاء/تعديل/دور/صلاحية/حارس	1–2 يوم	تراجع غير محمي
P3	**ميزات إدارة متقدمة**	Bulk Ops، استيراد/تصدير، قوالب أدوار، إعادة تعيين جماعي، تقارير، Role Hierarchy، Permission Groups	5–10 أيام	كفاءة إدارية

تصريف من A1: بند S6 «مصفوفة الصلاحيات الكاملة» مُعالَج في §1/§6 من هذه الوثيقة؛ ومعلومة «إعادة تعيين كلمة المرور» (A1 بند 9) مُوصَّلة في §3.6/§5–6.

ملحق أ — قائمة التوثيق الدائم (Documentation Mandate)

بموجب أمر التوثيق الدائم المرافق لـ CD-005، يُسجَّل هنا كل ما رُوجع، وكل مسار/شاشة/جدول، وكل ما لم يتضح.

أ‑1 الملفات التي رُوجعت

الملف	الحالة
الملف	الحالة
app/Controllers/Admin/UserController.php	كامل (352 سطرًا)
app/Controllers/Admin/RoleController.php	كامل (217 سطرًا)
app/Models/User.php	كامل (435 سطرًا)
app/Models/Role.php	كامل (182 سطرًا)
app/Core/Auth.php	كامل (670 سطرًا)
app/Core/Controller.php	كامل (78 سطرًا)
app/Core/Audit.php	كامل (45 سطرًا)
app/Controllers/ErrorController.php	كامل (51 سطرًا)
app/Views/admin/users/{index,create,edit}.php	كاملة (149/372/69)
app/Views/admin/roles/{index,create}.php	كاملة (176/44)
app/Views/layouts/header.php (المقاطع 395–419)	مُراجَع جزئيًا (قائمة الإدارة)
routes/web.php	كامل (382 سطرًا) — قسم admin 78–95
public/js/main.js (490–790)	مُراجَع
config/database.php	كامل
app/Controllers/AnalysisController.php:857–881	نمط mPDF RTL المرجعي
CD-001_delivery/A1_Authentication_Unit_Documentation.md	كامل (قالب البنية)
CD-001_delivery/{02,03,06,12,13}.md	مراجع مستهدفة (مصفوفة/نطاق/مخاطر/أمن)

الملف	الحالة
CHANGELOG.md (جذر + تسليم)	كامل

أ‑2 الجداول التي فُحصت (قراءة‑فقط)

roles, permissions, role_permissions, user_roles, users, audit_logs — عبر SHOW CREATE TABLE وSELECT مع mysql.exe --default-character-set=utf8mb4.

أ‑3 الشاشات التي رُصدت

admin/users/index, admin/users/create (تالف), admin/users/edit, نافذة تغيير الدور، admin/roles/index, admin/roles/create, نافذة تعديل الدور.

أ‑4 المسارات التي تُوبعت

15 مسارًا في §2.4) routes/web.php:79–95) — ولم يُعثر على admin/permissions.

أ‑5 ما لم يتّضح / إعلانات صريحة

1. **لماذا ملف create.php تالف؟** لا سجل Git في جذر المشروع (المستودع مستقل في CD-001_delivery)، فلا يُعرف تاريخ الاستبدال — يُعرض كواقع مُتحقَّق فقط.
2. **سبب عدم وجود سجلات تدقيق لـ0) ***ROLE_/USER_CREATE سجلات مقابل 40 لـ*_PERMISSION وَ3 لـUSER_UPDATE) لم يُحسم: يُرجَّح عدم استخدام الواجهات، وارتفاع AUTO_INCREMENT لـ682) audit_logs) من اختبارات/عمليات أخرى — يُعلن كغير مؤكد.
3. **مصدر الحسابات الحقيقية الأربعة** (sysadmin/kghamdi/smutairi/fzahrani) وطريقة إنشائها الأولية غير موثّق في الشيفرة (لا seed) — يُعلن.
4. **invited**: لا يوجد تدفق تفعيل فعلي (يُدرَج في OOS #10 من A1) — التبديل يقتصر على active/suspended.
5. **لقطات الشاشات الحية**: غير ملتقطة (تُوثَّق الشاشات من مصدر العرض) — ملحق لقطات اختياري إن توفرت لاحقًا.

نهاية الوثيقة — التوثيق التفصيلي للوحدة CD-005) A2)